security | Status: mixed | App v1.0.20 | Reviewed 2026-10-24

Security and Privacy

Sections 1–4 describe the code as it is **[current]**. Section 5 lists risks found in review. Section 6 gives recommendations **[proposed]**. Nothing here has been confirmed by a penetration test.

1. Privacy model

- **Inference is local.** Prompts, images, audio, and outputs go to LiteRT-LM, AICore, or MediaPipe on the device. No code path sends inference inputs to a server.
- **Opt-in exceptions:** the user may connect MCP servers or remote skills. Those receive whatever the model passes to them (tool arguments, the JS skill `data`).
- **Telemetry:** Firebase Analytics events carry model and task names, performance numbers, and device model and OS version. They are not supposed to carry prompt content **[inferred from event params]**. Analytics is off in OSS builds (no `google-services.json`), and the user can opt out in Settings.

2. Permissions (manifest)

Permission	Used by
`INTERNET`, `ACCESS_NETWORK_STATE`	Catalog, model downloads, Hugging Face, MCP, remote skills
`READ_MEDIA_IMAGES`, `READ_MEDIA_VIDEO`, `READ_MEDIA_VISUAL_USER_SELECTED`, `READ_EXTERNAL_STORAGE`, `ACCESS_MEDIA_LOCATION`	Instant Media Search, Video Moment Finder, image pickers
`CAMERA`	Ask Image capture, WebView skills (granted per request)
`RECORD_AUDIO`	Audio Scribe, dictation, WebView skills
`READ_CALENDAR`	`read_calendar_events` intent (requested at runtime)
`POST_NOTIFICATIONS`	Download progress, scheduled notifications, FCM
`FOREGROUND_SERVICE`, `FOREGROUND_SERVICE_DATA_SYNC`, `WAKE_LOCK`	WorkManager foreground downloads and indexing
`RECEIVE_BOOT_COMPLETED`	Restore scheduled notifications

Permission	Used by
`c2dm.permission.RECEIVE`, `READ_GSERVICES`, `GET_ACCOUNTS`	FCM / legacy GCM registration
`com.google.android.apps.aicore.service.BIND_SERVICE`	AICore

Exported components: `MainActivity` (launcher plus the `com.google.ai.edge.gallery://` deep-link scheme), the OSS license activities, and `BootReceiver` (`BOOT_COMPLETED`). The `FileProvider` isn't exported and grants URIs explicitly.

3. Data at rest

Data	Location	Protection
HF OAuth access token, refresh token, expiry	`filesDir/datastore/user_data.pb`	App sandbox only. **Not encrypted.**
Skill secrets (API keys)	`user_data.pb` (`secrets` map, key `skill___<name>`)	**Not encrypted**
MCP auth headers	`user_data.pb` (`mcp_auths`)	**Not encrypted**
Chat history (text, image file paths, audio)	`user_data.pb` and files	**Not encrypted**
Models	`getExternalFilesDir()`	App-specific external storage. No integrity check after download beyond size and status **[inferred]**.
HF token during a download	WorkManager input `Data` (`KEY_MODEL_DOWNLOAD_ACCESS_TOKEN`)	Stored in the WorkManager database until the work is pruned

`androidx.security:security-crypto` is a dependency, but no code calls `EncryptedFile`, `EncryptedSharedPreferences`, or `MasterKey`.

Backup: `android:allowBackup="true"`. `backup_rules.xml` and `data_extraction_rules.xml` are the **unmodified samples** (every rule commented out), so the platform's default backup rules apply **[inferred]**.

4. Network surface

Endpoint	Auth	Notes
`raw.githubusercontent.com/.../model_allowlists/<ver>.json`	none	Controls model URLs, revisions, and configs for every install of that version

Endpoint	Auth	Notes
`huggingface.co` (resolve, `/api`, OAuth)	Bearer token (optional)	`HttpURLConnection` over HTTPS
`api.github.com/repos/.../releases/latest`	none	New-release banner
User MCP servers	Optional custom header	StreamableHTTP over Ktor. Each call needs user consent unless always-allow.
Remote skill URLs	none	Pages load in a WebView with JavaScript enabled
Firebase	SDK	Only with `google-services.json`

5. Risks found in review

Severity is the reviewer's estimate. Cross-reference to 14-known-issues: SEC-01 = KI-02, SEC-02 = KI-03, SEC-03 = KI-17, SEC-04 = KI-04 and KI-05, SEC-05 = KI-01, SEC-06 = KI-06, SEC-07 = KI-21.

Id	Severity	Finding	Evidence
SEC-01	High **[to verify]**	**The local-skill WebView can read app-private files.** `BaseGalleryWebViewClient` serves `context.filesDir` at `https://appassets.androidplatform.net/` through `InternalStoragePathHandler`. Locally imported and built-in skills run on that same origin. Their JavaScript could `fetch('/datastore/user_data.pb')`, which contains the HF token, skill secrets, MCP headers, and chat history. Exfiltration needs a malicious skill the user imported.	`ui/common/GalleryWebView.kt:69-85`, `skills/SkillExtensions.kt`
SEC-02	Medium	Secrets and tokens are stored unencrypted, and default backup rules may include them in cloud backup or device transfer.	§3
SEC-03	Medium	The remote catalog is a single control point: anyone with write access to `main` can change model URLs for every user of that version. There's no signature or pinning on the allowlist.	`ModelManagerViewModel.loadModelAllowlist`

Id	Severity	Finding	Evidence
SEC-04	Low	Partial secrets go to logcat: `RunJsTool` logs the first 3 characters of a skill secret, and `DownloadWorker` logs the first 10 of the HF token. `secret.substring(0, 3)` also crashes on secrets shorter than 3 characters.	`tools/RunJsTool.kt:104`, `worker/DownloadWorker.kt:144`
SEC-05	Low	Token expiry buffer is 300 ms instead of the 5 minutes the comment states, so the app may use a token right as it expires.	`ModelManagerViewModel.getTokenStatusAndDat`
SEC-06	Low	`MainActivity` logs every intent extra (debug dump), including FCM payloads.	`MainActivity.onCreate/onNewIntent`
SEC-07	Info	The release build is **debug-signed**, with `isMinifyEnabled = false`, and `proguard-rules.pro` is referenced but absent. That's fine for CI artifacts, but distribution builds must use a different config.	`app/build.gradle.kts`
SEC-08	Info	The WebView has `allowFileAccess = true` and `javaScriptEnabled = true`.	`GalleryWebView.kt`

Controls already in place:

- zip-slip guard in `DownloadWorker`
- disclaimer dialogs before adding skills or MCP servers
- per-call MCP consent
- deep-link queries require confirmation (Agent Skills)
- the `FileProvider` isn't exported
- WebView permission requests are denied unless the screen allows them

6. Recommendations [proposed]

1. **SEC-01:** Serve imported skills from a dedicated directory (e.g. `filesDir/skills/`) instead of `filesDir` root. Put the WebView path handler on that directory only, and test that `/datastore/*` returns 404.
2. **SEC-02:** Encrypt `user_data.pb`, or move secrets and tokens to the Android Keystore through `EncryptedFile` (the dependency is already there). Exclude `datastore/` from backup in both rule files.
3. **SEC-03:** Sign the allowlist (or pin SHA-256 hashes per model file) and verify downloaded model hashes.
4. **SEC-04/06:** Remove token and secret logging and the intent-extra dump, or guard them with `BuildConfig.DEBUG`.

5. **SEC-05:** Use `5 * 60 * 1000L`.
6. Move the HF token out of WorkManager `Data`. Have the worker read it from the repository at execution time.